

Maine State Government
Dept. of Administrative & Financial Services
Office of Information Technology (OIT)

Data Exchange Policy

1.0. Statement

1.1. The Office of Information Technology (OIT) adopts all necessary measures to ensure that data exchanges with Maine State information assets comply with all relevant Federal and State Laws, as well as the industry best practices of Privacy and Security.

2.0. Background

2.1. The citizens of Maine trust their government with an immense cache of their data. It is essential for the State to reciprocate that trust with the best possible stewardship of that data.

2.2. Quality information is critical to effective government decision-making and fulfilling the government's obligation to its citizenry. This often necessitates exchanging data amongst the various agency information assets, as well as with external sources of information. It is essential that such exchanges comply with all relevant Federal and State Laws, Regulations, Statutes, and Rules, as well as the industry best practices of Privacy and Security.

2.3. Agencies are the caretakers of the data that they transact. While OIT handles the technical details, the Agency business units remain the fiduciary steward and custodian of their data.

3.0. Definitions

3.1. *Ad-hoc Data Exchange:* Any data exchange that is episodic and/or occasional. It is not economical to setup an automated process for such a transaction.

3.2. *Authorized Custodian:* An agency personnel who is empowered by a Federal or State Law, or Regulation, or Statute, or Rule, to asset stewardship of particular data transacted by that Agency.

3.3. *Bulk Data Transfer:* This is where the entirety of the transferred data is captured into files of pre-defined structure. Further, the transfer mechanism involves optimizing the transfer time through compression, blocking, and buffering.

3.4. *Data Classification:* The taxonomy of organizing data into categories, so that data may be used and protected efficiently. OIT subscribes to the U.S. Department of Homeland Security Cybersecurity and Infrastructure Security Agency (CISA) Traffic Light Protocol (TLP)[1] classification levels for this purpose. OIT's five classification levels can be found in section 7.0 of the Data Classification Policy.[2]

3.5. Data Exchange/Usage Agreement: A formal agreement between two parties that identifies the data being shared and the technical and security controls required to exchange it responsibly.

3.6. *Data Staging:* A location where data is temporarily stored during an extract, transform, and load procedure. This should be done with TLP: Clear data only.

3.7. *Maine Service Bus:* An enterprise platform that facilitates loosely-coupled, distributed, interoperable services that can be combined and reused rapidly.

3.8. *Net-New Data Exchange:* Any data exchange that did not exist heretofore, and is commencing for the first time.

3.9. *Personally Identifiable Information (PII):* Information that can be used on its own, or in combination with other information, to identify, contact, or locate a single person, or to identify an individual in context. Refer to Paragraph 6 of Maine Public Law 10 MRSA § 1347[3] for a more detailed definition. PII includes, but is not limited to, Protected Health Information (PHI), Federal Tax Information (FTI), and Federal Education Rights and Privacy Act (FERPA) Information.

3.10. *Standing Data Exchange:* Any data exchange that is meant to transpire at a fixed frequency, over a long period of time. This is likely accomplished through an automated process.

3.11. *Workflow Orchestration:* The process by which individual, atomic services are interconnected to create a more complex task that functions as a unit.

4.0. Applicability

4.1. This policy applies to:

4.1.1. Any data exchange that either originates or terminates with the Maine State Executive Branch, involving data classified as either Sensitive (TLP: Amber), (TLP: Amber+Strict) or Restricted (TLP: Red);

4.1.2. All State of Maine Executive Branch personnel, both employees and contractors; and

4.1.3. Executive Branch Information Assets, irrespective of hosting location.

[1] https://www.us-cert.gov/tlp
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf
[3] http://www.mainelegislature.org/legis/statutes/10/title10sec1347.html

5.0. Responsibilities

5.1. *Agency Management:*

5.1.1. Ensure that they have the authority to transact the data exchange, in accordance with all relevant Federal and State Laws, Regulations, Statutes, and Rules.

5.1.2. Ensure that every net-new, standing data exchange is undertaken according to a signed Data Exchange/Usage Agreement (DUA).

5.2. *Chief Information Officer:*

5.2.1. Owns, executes, and enforces this Policy.

5.3. *OIT Management:*

5.3.1. Ensures that the underlying technical details of the actual exchange comply with the industry best practices of Security and Privacy.

6.0. Directives

6.1. No net-new, standing data exchange can commence without a signed Data Exchange/Usage Agreement (DUA) amongst the Authorized Custodians of the transacted data. Exempted are cases where both the sender and receiver happen to be the same authorized custodian.

6.2. For a new-new, standing data exchange, the disposition of the data by the receiver is strictly in accordance with the signed Data Exchange/Usage Agreement (DUA).

6.3. Exchange of data can happen only after Authentication, and must be explicitly documented. The documentation burden is two-fold. First, the data exchange must be documented in the enterprise application repository. Second, each instance of the data exchange must be documented in a transactional log (most likely, the enterprise file transfer log). The purpose of documenting in the enterprise application repository is to identify this data exchange as an active enterprise data sharing, whereas the purpose of documenting in the transactional log is to meet the audit burden that this instance of data exchange did actually transpire.

6.4. All data exchanges transpire via industry-standard protocols, such as Web Services, HTTPS, FTPS, and SFTP. Per NIST 800-52,[4] the minimum acceptable level of dynamic encryption is TLS 1.2.

6.5. For any exchanged data, by default, the payload must be encrypted in-flight to the AES-256 standard, and the encryption key must be communicated separately from the payload. This directive may be superseded by a more specific instruction contained in relevant Federal and State Laws, Regulations, Statutes, and Rules.

6.6. By default, any ad-hoc external exchange happens through the enterprise Office 365. Ad-hoc, one-to-one external exchange happens through the user's OneDrive. Ad-hoc,

[4] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-52r2.pdf

one-to-many external exchanges happen through departmentally-approved SharePoint Sites and Document Libraries. However, under certain circumstances (such as, back-and-forth data sharing or collaboration between two parties), an enterprise-managed product may be used. Contact MaineIT Client Technologies for assistance with purchasing and/or installing an enterprise-managed product. More information on File Sharing within the State of Maine Enterprise can be found on the MaineIT Microsoft 365 Resources SharePoint Site (Internal-only)[5].

6.7. Any standing bulk data transfer happens through the enterprise Secure File Transfer service.

6.8. For any net-new, standing data exchange that is *not* a bulk transfer, the Maine Service Bus is the de-facto proxy. That does not mean that all net-new exchanges will be implemented on the Maine Service Bus. However, the burden of justification shifts to the non-use of the Maine Service Bus. Please refer to the Maine Service Bus Handbook[6] for further details.

6.8.1. A general exception is if the entire data exchange happens within the State of Maine Office 365 tenant.

6.8.2. As long as the Maine Service Bus remains on-premises, the other general exception is a cloud-to-cloud data exchange. However, when the Maine Service Bus migrates to the Oracle Cloud Infrastructure, this exception ceases to exist.

6.9. Nothing in the Data Exchange Policy can be construed as permission for a Site-to-Site Virtual Private Network (VPN) with the State Wide Area Network (WAN), or Directory Integration with the State.

7.0. Document Information

7.1. Initial Issue Date: 20 March 2020
7.2. Latest Revision Date: 17 April 2026
7.3. Point of Contact: PolicyTeam.OIT@Maine.Gov
7.4. Approved By: Chief Information Officer, OIT
7.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology 5F[7]
7.6. Waiver Process: Waiver Policy[8]

[5] https://stateofmaine.sharepoint.com/sites/MaineIT-O365
[6] https://stateofmaine.sharepoint.com/sites/MaineITEnterpriseDataServices/SitePages/MAINE-SERVICE-BUS.aspx
[7] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[8] https://maine.gov/oit/policies/waiver.pdf

8.0. Sample Data Exchange: Data Exchange/Usage Agreement (DUA)

DATA EXCHANGE/USAGE AGREEMENT (DUA)
BETWEEN
MAINE DEPARTMENT #1, AND
MAINE DEPARTMENT #2,
FOR THE EXCHANGE OF ARMADILLO DATA

8.1. Parties

8.1.1. The Maine Department #1 is authorized to collect and maintain Armadillo data, consistent with applicable State and Federal Laws.

8.1.2. The Maine Department #2 develops and disseminates conservation information to local officials, employers, educators, and the public, in making decisions that promote economic opportunity and efficient use of natural resources.

8.2. Purpose

The purpose of this DUA is to document the rules under which the Parties enumerated above shall transact Armadillo Data (the "Data"). Maine Department #1 must meet reporting and accountability measures required by the Armadillo Innovation and Opportunity Act 2019. The reporting requirements of this Law (Title I, Chapter 4, Section 116) cannot be met without data sharing with Maine Department #2. Hence, the Maine Department #1 will transmit enumerated elements of Armadillo Personally Identifiable Information (PII) to Maine Department #2.

8.3. Legal Authority

Consistent with the Family Educational Rights and Privacy Act (FERPA)[9], the Maine Department #1 may disclose Armadillo PII to its authorized partners in connection with enumerated Federal and State programs. See 20 U.S.C. §1232g(b)(3)[10] and 34 CFR Part 99.31(a)(3)[11].

8.4. Agreement Administrators

Each Party has assigned one Agreement Administrator to act on its behalf. It is the Agreement Administrators' responsibility to ensure compliance with this DUA and to serve as the official points-of-contact.

Agreement Administrator for Maine Department #1:
Name: _____
Title: _____
Address: _____
Telephone: _____

[9] https://www2.ed.gov/policy/gen/guid/fpco/ferpa/index.html
[10] https://uscode.house.gov/view.xhtml?req=(title:20%20section:1232g%20edition:prelim)
[11] https://www.law.cornell.edu/cfr/text/34/99.31

Email: _____

Agreement Administrator for Maine Department #2:
Name: _____
Title: _____
Address: _____
Telephone: _____
Email: _____

8.5. Records Transacted

8.5.1. Armadillo First Name
8.5.2. Armadillo Middle Initial
8.5.3. Armadillo Last Name
8.5.4. Armadillo ID Number
8.5.5. Armadillo Date of Birth
8.5.6. Armadillo Finishing School (if available)

8.6. Terms and Conditions

The receiving party, i.e., Maine Department #2, understands, and agrees to:

8.6.1. Comply with the provisions of FERPA, and applicable State Laws, in all respects. For the purposes of the DUA, FERPA includes all requirements of 20 U.S.C. § 1232g, and 34 CFR Part 99, and any amendments thereto. Nothing in this DUA may be construed to maintain, use, disclose, or share the Data in a manner *not* allowed by FERPA.

8.6.2. Require all employees, contractors, and agents of Maine Department #2 to comply with this DUA, and all applicable provisions of FERPA, and other Federal and State Laws, with respect to the Data. Maine Department #2 agrees to require of, and maintain, an appropriate confidentiality agreement with each employee, contractor, and agent with access to the Data. Nothing in this section authorizes Maine Department #2 to share the Data with any other individual, or entity, for any purpose, other than the stated Purpose of this DUA.

8.6.3. Under no circumstances nor in any way shall this DUA be construed to authorize Maine Department #2 to have access to additional data from the Maine Department #1.

8.6.4. Under no circumstances nor in any way shall this DUA be construed to convey ownership of the Data to Maine Department #2.

8.6.5. Maintain the Data separate from all other data possessed by the Maine Department #2, and not copy, reproduce, or transmit the Data, except as necessary to fulfill the stated Purpose of this DUA.

8.6.6. Except as authorized in a signed writing by Maine Department #1, do not disclose the Data in any manner that could identify any individual Armadillo to any entity or person other than authorized employees, contractors, and agents of Maine Department #2, for the stated Purpose of this DUA. Maine Department #1 shall have sole and exclusive authority to determine whether a disclosure of the Data is authorized by FERPA. Persons participating in approved work on behalf of the Parties under this DUA shall neither disclose, or otherwise release, data relating to an individual Armadillo, nor disclose information relating to a group of Armadillos, without ensuring the confidentiality of Armadillos in that group. Publications and reports of this data as well as any related information, including preliminary project descriptions, and draft reports, shall involve only aggregate data, and no PII, or other information that could lead to the identification of an Armadillo. No report of the Data, even in the aggregated form, shall be released to anyone, unless Maine Department #2 receives prior written approval from the Maine Department #1.

8.6.7. Provide the Maine Department #1 with electronic copies of the final versions of all reports prior to their presentation or release in order to allow the Maine Department #1 to review the compliance with this DUA. Maine Department #1 reserves the right to distribute, and otherwise use, any report, or other associated documents, as it wishes, in sum, or in part.

8.6.8. Permit the Maine Department #1 to review Maine Department #2's policies and procedures regarding PII, and seek written assurances from Maine Department #2 that the Data is properly handled. Maine Department #2 is expected to maintain strict policies and procedures to ensure that the Data is maintained in a secure manner that prevents further disclosure of the Data, including the interception, diversion, duplication, or other unauthorized access.

At a minimum, Maine Department #2 agrees to comply with the following:

8.6.8.1. Data storage administration will include the strict control of all storage media. All storage media must be inventoried on an annual basis, or sooner, as dictated by clients, regulatory, or other contractual agreements.

8.6.8.2. To the maximum extent possible, avoid physical backup and transfer of the Data, in favor of electronic transfer of encrypted backup files.

8.6.8.3. All data files and databases containing PII data will be encrypted at rest, using at least AES-256 encryption, or better, before being electronically transferred across any network, internal or public.

8.6.8.4. All data files and databases that contain PII data that are backed up to physical media for transfer to offsite storage, must be backed up using at least AES-256 encryption, or better. No unencrypted intermediate backup

files may be created.

8.6.8.5. Physical media containing PII data must be maintained in a secure environment prior to its transfer offsite.

8.6.8.6. Physical media containing PII data must be monitored during the internal shipping process, and must never be left unattended before handoff to the shipper.

8.6.8.7. Physical media containing PII data must be shipped in locked containers with no special markings, or other indications of the sensitive nature of the contents.

8.6.8.8. Shipping procedures must include a positive acknowledgement of receipt of encrypted media at the destination.

8.6.9. With respect to a suspected breach of the Data, report in detail to the Maine Department #1's Agreement Administrator within twenty-four (24) hours of first knowledge. It is also the responsibility of Maine Department #2 to develop a collaborative and expeditious remediation plan for the incident.

8.6.10. When the Data is no longer needed for the stated Purpose of this DUA, destroy it completely, including any archival/backup copies, per NIST SP 800-88, Guidelines for Media Sanitization.[12] Nothing in this DUA authorizes Maine Department #2 to maintain the Data beyond the time period reasonably needed to fulfill the stated Purpose of this DUA, and, in no case, beyond the termination date of this DUA. Any destruction of the Data must be witnessed by one other person who can later attest that a complete destruction of the Data did transpire. Maine Department #2 further agrees to submit a letter to the Maine Department #1, within 30 days of the termination of this DUA, attesting to the destruction of all Data.

8.6.11. This DUA takes effect immediately upon signature by the authorized representative of each Party and shall remain in effect until completion of the stated Purpose of this DUA, or until canceled by either Party upon 30 days' written notice. This DUA may be amended, or renewed, at the discretion of the Parties.

8.6.12. This DUA contains the entire agreement of the Parties, and shall not be modified or altered, except in writing, executed by the authorized representative of each Party, and in a manner consistent with applicable State and Federal Laws, Regulations, Statutes, and Rules.

8.6.13. No delay or omission by either Party in exercising any right under this DUA can be construed as a waiver of any right to which the Party may be entitled. A waiver or

[12] https://csrc.nist.gov/pubs/sp/800/88/r1/final

consent given by either Party, on any one occasion, is effective only in that instance, and will not be construed as a bar to, or a waiver of, any right, on any other occasion. Neither the review, nor approval, nor acceptance, nor payment, of any services under a separate Agreement, will be construed to operate as a waiver of any rights, or of any course of action, available to a Party pursuant to this DUA.

8.6.14. Any ambiguity in this DUA will *not* be construed against the Maine Department #1, but will be resolved by applying the most reasonable interpretation under the circumstances.

8.6.15. If any part of this DUA is held void, illegal, unenforceable, or in conflict with any Law, the validity of the remainder of this DUA will not be affected.

In witness whereof, the Parties have executed this DUA on the dates noted below:

Signatory for Maine Department #1:
Signature: _____
Name: _____
Title: _____
Date: _____

Signatory for Maine Department #2:
Signature: _____
Name: _____
Title: _____
Date: _____